

CORPORACIÓN UNIVERSITARIA MINUTO DE DIOS – UNIMINUTO

**Desarrollo de un modelo predictivo para la detección de anomalías de
autenticación mediante la metodología CRISP-DM en el sector salud**

Javier Eduardo Gomez Ovalle

Juan Camilo Ballares díaz

Minería de Datos

NRC DE LA MATERIA

NOMBRE DEL PROFESOR

Ibagué, Tolima. Abril de 2026

Contenido

1. Introducción	3
2. Fase 01: Comprensión del negocio	4
2.1. Antecedentes de la organización	4
2.2. Planteamiento del problema	5
2.2.1. Vector 1: Fuerza bruta y Credential Stuffing	6
2.2.2. Vector 2: Suplantación Silenciosa (Anomalía de Viaje Imposible)	6
2.3. Objetivo general	7
2.4. Objetivos específicos	7
2.4.1. Criterios de éxito cuantitativos	8
3. Fase 02: Comprensión del negocio	9
3.1. Fuente 1: RBA Dataset (Risk-Based Authentication Dataset, Kaggle)	9
3.2. Fuente 2: Catálogo IP–País–ASN (IPinfo Free IP to Country ASN Database)	10
3.3. Fuente 3: Maestro de Personal Hospitalario (empleados.csv, sintético)	11



UNIMINUTO
Corporación Universitaria Minuto de Dios
Educación de calidad al alcance de todos
Vigilada MinEduación

VERY GOOD



1. Introducción

2. Fase 01: Comprensión del negocio

2.1. Antecedentes de la organización

El presente proyecto se desarrolla sobre el estudio de caso de un Hospital Clínico Privado de Alta Complejidad el cual maneja diferentes tipos de servicios de salud (IPS), también cuenta con una unidad de cuidados intensivos (UCI), entre otras.

Este hospital al ser de cuarto y quinto nivel maneja grandes volúmenes de información de salud protegida (PHI), ya que el hospital trabaja 24/7, con turnos rotativos y médicos que trabajan en el área de urgencia en horas de la madrugada, esto quiere decir que la atención no se interrumpe aunque se realice en horarios no convencionales, esto representa un gran riesgo a nivel de datos y a nivel de acceso a la información, ya que un acceso ilegítimo fuera de horario y un acceso legítimo también fuera de horario, pasaría de forma inadvertida, esto lo hace un blanco fácil para cualquier atacante.

2.2. Planteamiento del problema

A partir de reportes previos del equipo de seguridad de la información, se ha identificado que el vector de ataque más probable y de mayor impacto, no corresponde a una explotación de una vulnerabilidad del software, sino mas bien al abuso de credenciales legítimas.

El planteamiento anterior corresponde correctamente con el framework MITRE ATT&CK, en este se hace énfasis en la técnica T1078(Valid accounts), aquí se documenta como una vía de acceso inicial que, al usar credenciales validas, es capaz de pasar por todos los controles perimetrales tradicionales tales como (firewalls, IPS/IDS basados en firmas), esto obliga a que se realice un enfoque de detección basado en el comportamiento del usuario (UEBA, que por sus siglas: “User and Entity Behavior Analytics”).

Con toda la información anterior, se llegó a la conclusión de que se tienen que monitorear 2 vectores de compromiso de autenticación.

2.2.1. Vector 1: Fuerza bruta y Credential Stuffing

Este vector corresponde al acceso mediante una prueba iterativa de credenciales, estos pueden ser mediante diccionario (fuerza bruta clásica) o por reutilización de pares-contraseña (Credential Stuffing). Para reconocer este evento, se hace mediante una serie muy repetitiva de eventos con el campo “Login Succesful = FALSE”, estos normalmente realizados desde una misma IP o desde IPs perteneciente a IABs conocidos.

2.2.2. Vector 2: Suplantación Silenciosa (Anomalía de Viaje Imposible)

Este vector corresponde al escenario más sigiloso de todos ya que el atacante obtiene una credencial valida desde el inicio, esto mediante phishing o comprada a un IAB, y la utiliza sin generar fallos de autenticación, ya que el campo “Login Succesful” siempre será = TRUE las reglas simples basadas en conteo de intentos no detectaran nada anómalo. Para este caso se usará un indicador operativo geográfico-temporal, es decir, si el mismo “USER ID” se autentica de forma exitosa desde Bogotá y 30 minutos después de autentica exitosamente desde Paris, en este caso siendo una ubicación físicamente inalcanzable en ese lapso, se configurará la anomalía conocida como Impossible travel.

2.3. Objetivo general

Desarrollar un modelo predictivo basado en minería de datos para identificar inicios de sesión sospechosos en el hospital, ayudando a detectar de forma automática cuándo un atacante externo está intentando suplantar la identidad de un empleado.

2.4. Objetivos específicos

- Fusionar tres fuentes de datos independientes: el registro histórico de autenticaciones (RBA Dataset), el catálogo de geolocalización IP-País (IPinfo) y el maestro sintético de personal hospitalario en un único archivo de trabajo en Python utilizando la librería Pandas.
- Crear variables de comportamiento basadas en ciberseguridad, como el número de intentos fallidos para detectar "fuerza bruta" y la ubicación geográfica para detectar "viajes imposibles".
- Entrenar un algoritmo de Árbol de Decisión que sea fácil de entender y graficar, permitiendo explicar de manera clara y visual por qué el sistema clasifica un acceso como normal o como ataque.
- Evaluar el rendimiento del modelo utilizando métricas específicas para datos desbalanceados, esto con el fin de garantizar una alta efectividad en la detección de amenazas reales sin ir a saturar el sistema con falsas alarmas.

2.4.1. Criterios de éxito cuantitativos

En un Dataset de autenticación real, los eventos anómalos representan una fracción minúscula del total (normalmente inferior al 2-3% de la clase positiva), es por esto que usar una métrica como Accuracy no sería viable ya que un modelo tan trivial que clasifique todo como “normal”, alcanzaría una exactitud por encima del 97% sin detectar ni un solo ataque.

- Recall (Sensibilidad) ≥ 0.80 sobre la clase minoritaria (anómala): un Recall bajo implica un alto número de Falsos Negativos, es decir, ataques reales que el sistema clasifica como tráfico legítimo. En el contexto de protección de PHI, un Falso Negativo es el error de mayor costo de negocio, pues equivale a una brecha de datos no detectada.
- F1-Score ≥ 0.80 sobre la clase minoritaria: al ser la media armónica entre Precisión y Recall, este indicador garantiza que la mejora del Recall no se logre a costa de saturar al equipo del SOC con Falsos Positivos (fatiga de alertas), un fenómeno ampliamente documentado como causa de baja adopción de sistemas de detección en centros de operaciones de seguridad.

3. Fase 02: Comprensión del negocio

3.1. Fuente 1: RBA Dataset (Risk-Based Authentication Dataset, Kaggle)

Este es el núcleo del proyecto, es un histórico de eventos de autenticación web con más de 33 millones de filas, las cuales corresponden a un servicio de inicio de sesión con instrumentación de riesgo (Risk-Based Authentication).

Campo	Tipo	Rol en el proyecto
Login Timestamp	Fecha/Hora	Base para los indicadores de fuera de horario y viaje imposible.
User ID	Texto/Numérico	Llave foránea hacia el maestro de empleados.
IP Address	Texto (IPv4/IPv6)	Llave de cruce (tras conversión a entero) hacia el catálogo IPinfo.
Country	Texto	País de acceso reportado por el proveedor de autenticación; se contrastará contra el país resuelto vía IPinfo como control de calidad cruzado.
Round-Trip Time [ms]	Numérico	Variable auxiliar de latencia de red; potencial indicador indirecto de uso de VPN o proxy.
Device Type / User Agent String	Texto	Insumo para detectar cambios abruptos de dispositivo o navegador en un mismo 'User ID'.
Login Successful	Booleano	Base directa del indicador de fuerza bruta / Credential Stuffing (ráfagas de False).
Is Attack IP / Is Account Takeover	Booleano	Variables de referencia (ground truth) provistas por el Dataset original, utilizadas para validar y, en su defecto, complementar la variable objetivo-construida por el estudiante.

3.2. Fuente 2: Catálogo IP–País–ASN (IPinfo Free IP to Country ASN Database)

Esta tabla corresponde al catálogo público de geolocalización de rangos de direcciones IP, a diferencia de una tabla convencional, esta no contiene una columna de IP convencional sino mas bien un rango de IPs definidos por un limite inferior y uno superior.

Campo	Tipo	Descripción
start_ip	Texto (IP)	Dirección IP inicial del rango.
end_ip	Texto (IP)	Dirección IP final del rango.
country	Texto	Código ISO 3166 del país (p. ej., CO, US).
country_name	Texto	Nombre completo del país.
continent / continent_name	Texto	Código y nombre del continente.
asn	Texto	Número de Sistema Autónomo (Autonomous System Number).
as_name	Texto	Nombre de la organización propietaria del AS.
as_domain	Texto	Dominio oficial de dicha organización.

3.3. Fuente 3: Maestro de Personal Hospitalario (empleados.csv, sintético)

Debido a la inexistencia de un directorio activo (Active Directory) público y real de una institución hospitalaria, se construirá un maestro sintético al cual se le asignaran roles y un perfil de hospital privado coherente, pero sin omitir el importante detalle de que los valores de “USER ID” deben coincidir de forma exacta con un subconjunto de los “USER ID” reales.

Campo	Tipo	Descripción
User ID	Texto	Llave primaria; extraída directamente del RBA Dataset (no generada).
Nombre_Completo	Texto	Nombre sintético generado con Faker, sin valor analítico propio (anonimización por diseño).
Rol_Hospitalario	Categórico	Cargo dentro del hospital; variable clave para la hipótesis de variabilidad horaria por rol.
Pais_Residencia	Categórico	País de residencia declarado del empleado; base de la variable de discordancia geográfica.
Turno_Asignado	Categórico	Franja horaria oficial de trabajo; contraste directo contra el indicador de acceso fuera de horario.
Estado_Cuenta	Categórico	Activo/Inactivo; un acceso exitoso proveniente de una cuenta 'Inactivo' es, por definición de negocio, un evento de máxima prioridad.